Insight Assurance

Delivering Quality, Assuring Trust.

System and Organization Controls (SOC) 3
Report on OpenAI OpCo, LLC 's ChatGPT and API Services Relevant to Security and Confidentiality Throughout the Period July 1, 2024, to December 31, 2024

OpenAI

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:57763Z

SAFEBASE

TABLE OF CONTENTS

SECTION 1: INDEPENDENT SERVICE AUDITOR'S REPORT ON A SOC 3 EXAMINATION **1**

INDEPENDENT SERVICE AUDITOR'S REPORT 2

SECTION 2: OPENAI OPCO, LLC'S MANAGEMENT ASSERTION **4**

OPENAI OPCO, LLC'S MANAGEMENT ASSERTION 5

ATTACHMENT A – DESCRIPTION OF THE SYSTEM BOUNDARIES **6**

DESCRIPTION OF THE BOUNDARIES OF THE CHATGPT AND API SERVICES 7

ATTACHMENT B – PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS **13**

PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS 14

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:09:59.713Z

INDEPENDENT SERVICE AUDITOR'S REPORT

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.763Z

Insight Assurance
Delivering Quality, Assuring Trust.

INDEPENDENT SERVICE AUDITOR'S REPORT ON A SOC 3 EXAMINATION

To: OpenAI OpCo, LLC

Scope

We have examined OpenAI OpCo, LLC's ("OpenAI") accompanying assertion titled "OpenAI OpCo, LLC's Management Assertion" (assertion) that the controls within the ChatGPT and API Services (system) were effective throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the trust services criteria relevant to Security and Confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus – 2022) in* AICPA, *Trust Services Criteria*.

Service Organization's Responsibilities

OpenAI is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved. OpenAI has also provided the accompanying assertion about the effectiveness of controls within the system. When preparing its assertion, OpenAI is responsible for selecting, and identifying in its assertion, the applicable trust services criteria and for having a reasonable basis for its assertion by performing an assessment of the effectiveness of the controls within the system.

Service Auditor's Responsibilities

Our responsibility is to express an opinion, based on our examination, on management's assertion that controls within the system were effective throughout the period to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether management's assertion is fairly stated, in all material respects. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the engagement.

Our examination included:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements.

Asad Mansoor, asad@cloudcraftstudio.com, 2025-04-17T16:08:59.763Z

SAFEBASE

- Assessing the risks that controls were not effective to achieve OpenAI OpCo, LLC's service commitments and system requirements based on the applicable trust services criteria.
- Performing procedures to obtain evidence about whether controls within the system were effective to achieve OpenAI OpCo, LLC's service commitments and system requirements based on the applicable trust services criteria.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Inherent Limitations

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Opinion

In our opinion, management's assertion that the controls within the ChatGPT and API Services were effective throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI OpCo, LLC's service commitments and system requirements were achieved based on the applicable trust services criteria is fairly stated, in all material respects.

Insight Assurance LLC

Tampa, Florida
February 21, 2025

Asad Mansoor, asad@cloudconformstudio.com, 2025-04-11T16:08:59.763Z

OPENAI OPCO, LLC'S MANAGEMENT ASSERTION

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.763Z

OpenAI

OPENAI OPCO, LLC'S MANAGEMENT ASSERTION

We are responsible for designing, implementing, operating, and maintaining effective controls within OpenAI OpCo, LLC's ("OpenAI") ChatGPT and API Services throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the trust services criteria relevant to Security and Confidentiality (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus – 2022),* in AICPA *Trust Services Criteria*. Our description of the boundaries of the system is presented in Attachment A and identifies the aspects of the system covered by our assertion.

We have performed an evaluation of the effectiveness of the controls within the system throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the applicable trust services criteria. OpenAI's objectives for the system in applying the applicable trust services criteria are embodied in its service commitments and system requirements relevant to the applicable trust services criteria. The principal service commitments and system requirements related to the applicable trust services criteria are presented in Attachment B.

There are inherent limitations in any system of internal control, including the possibility of human error and the circumvention of controls. Because of these inherent limitations, a service organization may achieve reasonable, but not absolute, assurance that its service commitments and system requirements are achieved.

We assert that the controls within the system were effective throughout the period July 1, 2024, to December 31, 2024, to provide reasonable assurance that OpenAI's service commitments and system requirements were achieved based on the applicable trust services criteria.

OpenAI OpCo, LLC
February 21, 2025

Asad Mansoor, asad@cloudconformitystudio.com, 2025-04-11T16:09:59.760Z

SAFEBASE

ATTACHMENT A DESCRIPTION OF THE BOUNDARIES OF THE CHATGPT AND API SERVICES

Asad Mansoor, asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.763Z

ATTACHMENT A

OPENAI OPCO, LLC'S DESCRIPTION OF THE BOUNDARIES OF ITS CHATGPT AND API SERVICES

SERVICES PROVIDED

OpenAI develops foundation models and makes their capabilities available to business users through two main services: the Application Programming Interface ("API") Platform and the business suite of ChatGPT applications ("ChatGPT"), including ChatGPT Team, ChatGPT Enterprise, and ChatGPT Edu ("ChatGPT and API Services"). The consumer version of ChatGPT is excluded from this service description.

API

OpenAI's API Platform enables developers to integrate the capabilities of our models into their own applications. The API can be utilized for a wide range of tasks involving the understanding or generation of natural language, code, and other content. OpenAI offers a range of models with different capabilities and price points, along with the ability to fine-tune custom models to meet specific needs.

ChatGPT

OpenAI's ChatGPT Services allows users to interact with OpenAI's models through a conversational interface. Users can request the models to analyze or generate text and code or create images based on text descriptions. ChatGPT is available for business users as ChatGPT Team, ChatGPT Enterprise, and ChatGPT Edu. Business services include robust security controls, with ChatGPT Enterprise providing additional features such as SAML Single Sign On (SSO), enhanced administrative controls, and priority support.

OpenAI maintains consistent security commitments across all its services. By default, OpenAI does not use business data for training our models. Both ChatGPT Enterprise and the API provide enterprise-level authentication. Additionally, all OpenAI services offer fine-grained control over access and features, including the customization of models developed by users.

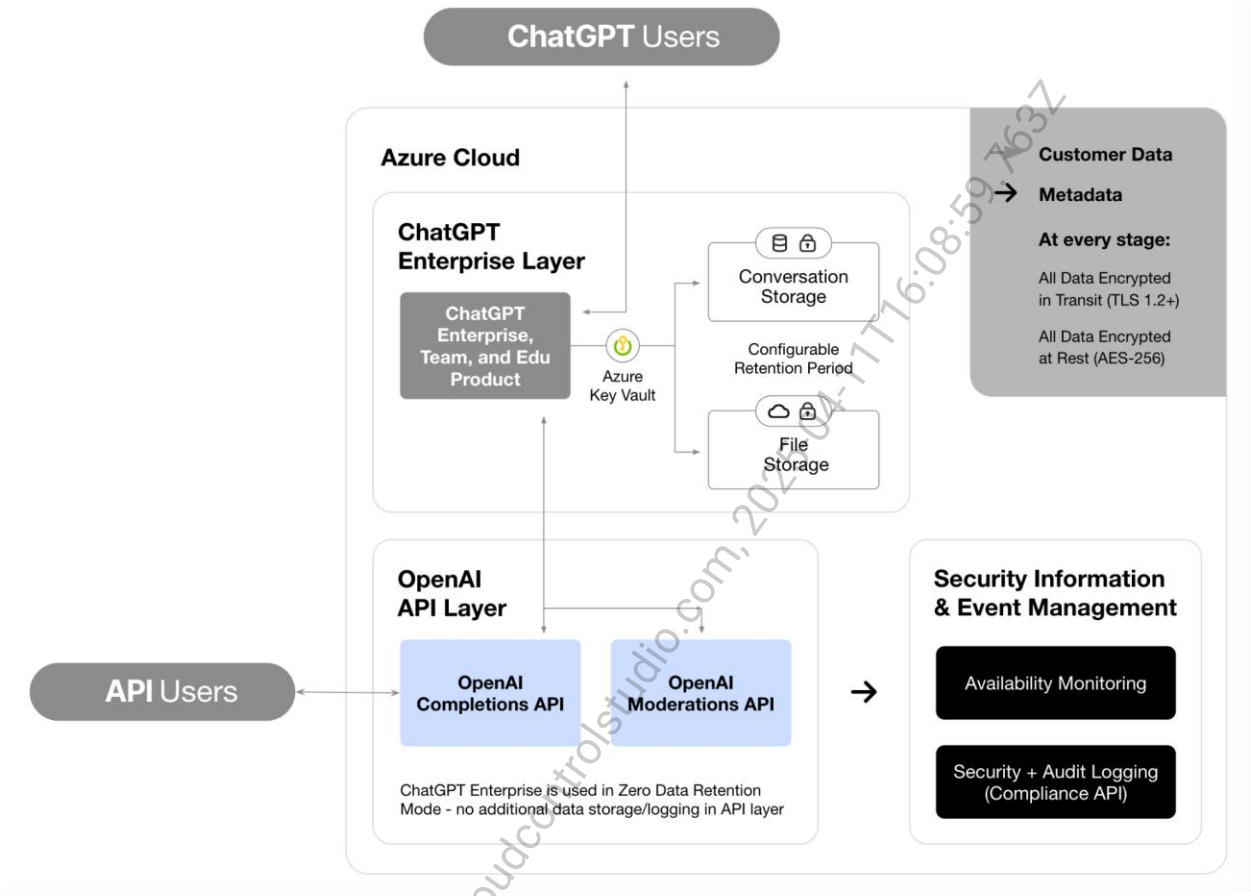
INFRASTRUCTURE

OpenAI's ChatGPT and API Services are deployed in a multi-tenant architecture. The System's application infrastructure is hosted by both Microsoft Azure and Snowflake, which provide scalable cloud hosting and data warehousing services as subservice organizations. Azure Cloud Services manage physical security, environmental protection, and network security with advanced firewall and network protection capabilities.

OpenAI's Information Security Policy ensures that workstations and servers are equipped with appropriate security software and regularly updated with the latest patches. In the event of security threats, automated systems respond with quarantine or removal actions, as necessary. If needed, infected machines are isolated from the network for remediation. The IT and Security departments jointly maintain defenses and monitor vulnerabilities across the network and application infrastructure, adhering to established SLAs.

Asad Ansari, asad@cloudcontrolled.com, 2025-04-17T16:08:55 7 of 7

Security monitoring includes multiple layers of traffic detection for malicious content. Third-party penetration tests are conducted annually to identify vulnerabilities and assess the security of production systems. Additionally, all employee workstations meet minimum security standards, and backup workstations are maintained to minimize operational disruptions.



ChatGPT and API

Adam Mansour asad@cloudcontrolstudio.com, 2025-04-11T16:08:59.763Z

SOFTWARE

OpenAI maintains an up-to-date inventory of critical software used in its environment, ensuring all necessary software licenses are documented. Key software components include the following:

Third Party Software	
Software	**Description**
Microsoft Entra ID	Identity and access management service
Tailscale	VPN
Buildkite	Continuous integration service
CrowdStrike Falcon	Endpoint protection
Databricks	SIEM
Cloudflare	Firewall

Third Party Software	
Software	**Description**
Datadog	System Monitoring
GitHub	Source code management
Isovalent Cilium	Intrusion detection system/intrusion prevention system (IDS/IPS)
Jamf	Mobile device management solution
Jira	Ticketing system
Wiz	Vulnerability scanner

PEOPLE

OpenAI employs dedicated teams for all major product functions, including development, operations, and support, organized into the following functional areas:

- **Executive Leadership**: Responsible for setting the vision, mission, and values of OpenAI, as well as overseeing the strategic direction, governance, and compliance of the organization. Also responsible for ensuring alignment of HR policies, practices, and processes with OpenAI's culture and objectives.
- **Applied Engineering**: Responsible for developing, testing, deploying, and maintaining OpenAI's API and ChatGPT Services, as well as other AI applications and services. Also responsible for adhering to security, quality, and performance standards throughout the software development lifecycle.
- **IT**: Responsible for managing and maintaining OpenAI's IT corporate infrastructure, systems, and networks, as well as providing technical support and guidance to users. Also responsible for implementing and enforcing security controls, policies, and procedures to protect OpenAI's data and assets.
- **Security**: Oversees the implementation of information security controls for infrastructure and IT processes; responsible for the design, development, implementation, operation, maintenance, and monitoring of cyber security controls; communicates information security risks to executive leadership.
- **People Operations Team**: Responsible for recruiting, hiring, onboarding, and retaining OpenAI's employees, as well as providing payroll, benefits, and performance management services. Also responsible for fostering a diverse, inclusive, and ethical work environment, as well as promoting OpenAI's values and culture.

DATA

OpenAI defines Customer Data as the electronic data or information submitted by the Customer or Authorized Parties to OpenAI's service. Customer data is securely managed, processed, and stored in compliance with relevant data protection regulations and established customer agreements. Customer Data is utilized by OpenAI in delivering its API Platform and ChatGPT Services. Customer Data is stored following industry best practices. Access to this data is restricted by technical and policy controls, and limited to employees whose job function requires

Asad Hasson, asad@cloudcontrolstudio.com 2025-04-11T16:08:59.763Z

it, in accordance with OpenAI's Privacy Policy and Terms of Use. All data managed, processed, or stored by OpenAI is subject to an internal classification system defined in our Data Management Policy.

All employees and contractors of OpenAI are obligated to respect and, in all cases, to protect customer data. Customer information, employment-related records, and other intellectual property-related records are subject to limited exceptions, confidential as a matter of law, and employment agreements signed by OpenAI employees. Many other categories of records, including Company and other personnel records and records relating to OpenAI's business and finances, are, as a matter of OpenAI policy, treated as confidential. Responsibility for guaranteeing appropriate security for data, systems, and networks is shared by the Applied Engineering, IT, and Security departments. IT and Security are responsible for designing, implementing, and maintaining security protection of the data. They also retain responsibility for ensuring compliance with the policy. In addition to management and the technology staff, individual users are responsible for the equipment and resources under their control.

OpenAI has policies and procedures in place to ensure proper retention and disposal of customer data. The retention and data destruction policies define the retention periods and proper destruction procedures for the disposal of data. These policies are reviewed at least annually. ChatGPT Enterprise customers can configure a retention window, with a minimum period of 90 days. For all Services, deleted data will be removed from our system within 30 days, after the data is marked for deletion, regardless of the selected retention period. In addition, customer data is never used in the development or training of new models.

The confidentiality of electronic communications is secured to a high standard. Networks are protected by enterprise-class firewalls and appropriate enterprise-class virus protection is in place. Password protection with assigned user rights is required for access to the network, application, and databases. Access to the network, application, and databases is restricted to authorized internal and external users of the System to prohibit unauthorized access to confidential data.

OpenAI uses centrally managed role-based access control and requires users to be authenticated prior to the use of any resources. Users' access requests for resources are validated against the user's authorized roles in Microsoft Entra ID. Employees are authenticated using multi-factor authentication. Additional access controls include the broad use of single sign-on, device certificates for single sign-on, and tools to defend against phishing, malware, and other risks borne from general web activity.

PROCEDURES

Management has developed formal IT policies and procedures that describe logical access, computer operations, change management, incident management, vulnerability management, and data communication standards to obtain the stated objectives for network and data security, data privacy, and integrity for both the Company and its customers and define how services should be delivered. These are communicated to employees and are located within the organization's intranet. OpenAI reviews and updates its policies and procedures as required, at least annually.

Asad Mansour, asad@cloudcontrolstudio.com 2025-01-17 16:03:39 PST

Reviews and changes to these policies and procedures are performed annually and are approved by senior management.

Physical Security and Environmental Controls

Azure and Snowflake, as the subservice provider hosting services, are responsible for implementing physical security controls over data centers for in-scope systems.

Logical Access

OpenAI has taken steps to centralize and secure its identity and access management services. These controls include mandatory multi-factor authentication for employees, broad use of single sign-on (SSO), device certificates for SSO, and tools to defend against phishing, malware, and risks borne from general web activity. OpenAI uses role-based access control architecture and requires users of the System to be identified and authenticated prior to the use of any resources. Resources are protected through an identity management solution that identifies, authenticates, and validates access requests against the user's authorized roles in Microsoft Entra ID. Elevated privileges are limited by role, require approval, time limited, and logged.

Logical access to OpenAI's networks, applications, and data is limited to properly authorized individuals. For OpenAI employee authentication, logical access is controlled via mandatory multi-factor authentication. For customer authentication, logical access is controlled via standard user authentication credentials (user ID and password). API Platform and ChatGPT Enterprise customers can leverage single sign-on. ChatGPT for business administrators can also leverage the Admin Dashboard to centralize and manage user access for their workspace.

Change Management

OpenAI maintains documented Secure Development policies and procedures to provide appropriate oversight and documentation for application and infrastructure changes. Change management procedures include change request and initiation processes, documentation requirements, development practices, testing requirements, required approval, and planned upgrade and maintenance procedures. OpenAI uses code versioning software for source control management and makes changes to its repositories via pull requests. The documentation of change management procedures is maintained in our source code platform.

In the event of an emergency, change management procedures are still applied but on an accelerated timeline. Documentation occurs but may be outside the typical location in our source code platform. Additionally, OpenAI maintains rollback capabilities to minimize the impact of change-related incidents, such as errors, defects, outages, or breaches.

Patch Management

The Security Team monitors advanced notifications of bug-related patches that are disclosed prior to a public announcement by the vendor. The IT, Security, and Applied Engineering teams review the availability of patches and independently determine if they are necessary to deploy within the production environment. Approved patches are scheduled for installation in the staging environment. If there are no issues in the staging environment, the patch will be applied to the production environment. The patching process is tracked and documented.

Asad Hussain, a_a@cloudcontrolstudio.com 2025-04-17T16:08:19Z

Incident and Vulnerability Management

OpenAI maintains an Incident Response Plan that describes the process for identifying and addressing potential security incidents. The policy details steps to take if an incident is suspected. Plans for detecting, responding to, and recovering from incidents are included in the policy, and post-incident activity requirements are defined. To ensure that responsible employees are prepared to respond to incidents, the organization conducts incident response exercises.

The organization provides a Bug Bounty Program where customers can report potential security vulnerabilities, and customers are also provided with an email for this same purpose. Internal users are directed to report incidents through an internal portal for documentation and tracking purposes.

System Monitoring

The Operations Security Policy describes the organization's policies and procedures related to network and system logging, monitoring, as well as vulnerability identification and remediation. The organization uses Azure logs from Azure services for system logging, and the organization collects logs from systems throughout its environments. Azure and application logs document source IP, destination IP, destination port, protocol type, and timestamp. The organization monitors system capacity to ensure availability. Logs are aggregated in Databricks and OpenAI runs custom queries to detect and respond to security events.

Cloudflare and custom Cilium network policies and logs are used for threat detection purposes. The tools used generate logs, network telemetry, and DNS logs for intrusion detection.

The vulnerability assessment process involves continuous monitoring of endpoints with antivirus and vulnerability scanning software, including system patching of third-party dependencies. The organization uses CrowdStrike Falcon endpoint protection and has configured the software to run updates daily and prohibit end-users from disabling the software. The organization uses Wiz vulnerability management and alerting. Alerts are sent immediately when a potential virus or vulnerability is detected, and logs are generated and retained.

Vendor Management

The organization maintains a Third-Party Management Policy that includes requirements for interacting with third party vendors. The policy includes requirements for performing due diligence measures prior to engaging with new vendors. Due diligence procedures include evaluating each vendor's functionality, services, risk, security, compliance, and performance. The organization monitors its vendors' compliance with the agreed upon security and confidentiality agreements. The organization executes non-disclosure agreements with third parties before any information is shared.

Asad Nanabhay, asad@cloudsecuritystudio.com, 2025-04-11T16:08:50.162Z

ATTACHMENT B
PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS

Asad Mansoor, asad@cloudcomputingstudio.com, 2025-04-11T16:08:59.763Z

ATTACHMENT B

PRINCIPAL SERVICE COMMITMENTS AND SYSTEM REQUIREMENTS

OpenAI designs its processes, procedures, and controls for ChatGPT and API Services ("system") to meet its service commitments, legal and regulatory requirements, and internal standards. Security commitments are detailed in customer agreements and online service descriptions, and include:

- **Logical Access Control**: Security principles are embedded in the core designs of OpenAI's Services to ensure system users can access only the information necessary for their roles, preventing unauthorized access to data not pertinent to their functions.
- **Encryption**: Customer data is protected with encrypted technologies both at rest and in transit, ensuring secure communication between customers and the System, as well as between the System and service providers.
- **Data Retention and Disposal:** Data retention and disposal processes are aligned with OpenAI's retention policies and are executed upon customer initiation or request.

Operational requirements support security, legal, and regulatory compliance and are communicated through policies, system design documentation, and customer agreements. Information security policies cover system design, development, operation, and employee management. OpenAI specifies processes for the operation and development of the system.

Asad Mansoor, asad@cloudcontrolstudio.com 2025-04-11T16:38:52.763Z